

Risk Management Strategy Report

This report demonstrates the application of risk management principles by identifying and addressing risks derived from vulnerability scan results, focusing on two critical risks with detailed explanations, treatment recommendations, and mitigation steps. Additionally, it includes a risk monitoring procedure to track identified risks. All assessments and procedures are documented with justifications for decisions made.

1. Risk Identification from Vulnerability Scan Results

The vulnerability scan results referenced here are based on the hypothetical Nmap scan output from the previous "Vulnerability Assessment Report" (artifact_id: af6887ed-94fc-43d2-8c98-04a28cdc10e4). The scan targeted a Linux server (192.168.1.100) and identified vulnerabilities in services such as SMB, HTTP, and SSH. Below, two critical risks are selected for detailed analysis.

1.1 Critical Risk 1: SMB Vulnerability (EternalBlue Exploit)

Description: The SMB service (Samba 4.11.2) on port 445/tcp is vulnerable to the EternalBlue exploit (CVE-2017-0144, CVSS 9.8). This vulnerability allows unauthenticated remote code execution, enabling attackers to gain full control of the system.

Risk Explanation:

Likelihood: High. EternalBlue is widely exploited, with public exploit code available (e.g., in Metasploit). The service is exposed to the internal network, increasing the risk of lateral movement if an attacker gains initial access.

Impact: Severe. Successful exploitation can lead to complete system compromise, data theft, ransomware deployment, or network-wide propagation (e.g., WannaCry-like attacks).

Threat Context: This vulnerability is commonly targeted by advanced persistent threats (APTs) and automated malware campaigns, as seen in historical attacks like WannaCry and NotPetya.

Justification for Selection: The CVSS score of 9.8 and the exploit's history of widespread damage make this a critical risk requiring immediate attention.

1.2 Critical Risk 2: Outdated Apache Version (CVE-2021-41773)

Description: The HTTP service (Apache 2.4.41) on port 80/tcp is vulnerable to CVE-2021-41773 (CVSS 7.5), a path traversal and remote code execution vulnerability. Attackers can exploit this to access sensitive files or execute arbitrary code on the server.

Risk Explanation:

Likelihood: High. The vulnerability is publicly disclosed with available exploits, and the service is internet-facing, making it a prime target for automated scanners and attackers.

Impact: High. Exploitation can result in server compromise, data leakage, or defacement of the web application hosted on the server. If the server hosts critical applications, the impact could extend to business operations.

Threat Context: Web servers are frequent targets for exploits due to their exposure. This vulnerability has been actively exploited in the wild, as reported by security advisories.

Justification for Selection: The high CVSS score and internet-facing nature of the service elevate this to a critical risk, as it poses a direct threat to the organization's web infrastructure.

2. Treatment Recommendations and Mitigation Steps

2.1 Treatment for SMB Vulnerability (EternalBlue)

Treatment Strategy: Mitigate and Avoid

Mitigate: Apply patches and harden configurations to reduce the likelihood of exploitation.

Avoid: Disable SMB if not required to eliminate the risk entirely.

Mitigation Steps:

Patch Management:

Upgrade Samba to the latest version (e.g., 4.15 or higher) to address CVE-2017-0144.

Command: `sudo apt-get update && sudo apt-get upgrade samba`

Justification: Patching removes the vulnerability, addressing the root cause.

Disable SMB (if not required):

Stop and disable the SMB service: `sudo systemctl stop smbd && sudo systemctl disable smbd`

Justification: Disabling unused services reduces the attack surface.

Firewall Configuration:

Block port 445/tcp on the firewall for external traffic: `sudo ufw deny 445`

Allow only specific internal IPs if SMB is needed.

Justification: Restricting access limits exposure to potential attackers.

Network Segmentation:

Place the server in a segmented VLAN to limit lateral movement.

Justification: Segmentation contains the impact of a breach.

Residual Risk: Low, assuming patches are applied and SMB is disabled or restricted.

Unpatched systems or misconfigured firewalls could leave residual risk.

2.2 Treatment for Apache Vulnerability (CVE-2021-41773)

Treatment Strategy: Mitigate

Mitigate: Patch the Apache server and implement defensive measures to prevent exploitation.

Mitigation Steps:

Patch Management:

Upgrade Apache to a version that addresses CVE-2021-41773 (e.g., 2.4.51 or higher).

Command: `sudo apt-get update && sudo apt-get upgrade apache2`

Justification: Patching eliminates the vulnerability, preventing exploitation.

Web Application Firewall (WAF):

Deploy a WAF (e.g., ModSecurity) to filter malicious HTTP requests targeting path traversal patterns.

Example rule: Block requests containing `../` or `%2e%2e%2f`.

Justification: A WAF provides an additional layer of protection against exploit attempts.

Access Controls:

Restrict access to the web server to specific IP ranges using `.htaccess` or firewall rules.

Example `.htaccess`: `<RequireAll>`

`Require ip 192.168.1.0/24`

</RequireAll>

Justification: Limiting access reduces the attack surface.

Regular Scanning:

Schedule weekly vulnerability scans using Nmap or OpenVAS to detect new vulnerabilities.

Justification: Ongoing scanning ensures timely identification of new risks.

Residual Risk: Medium, as patching eliminates the specific vulnerability, but web servers remain high-value targets. Misconfigurations or new vulnerabilities could introduce residual risk.

3. Risk Monitoring Procedure

3.1 Procedure: Continuous Risk Monitoring for Identified Vulnerabilities

Objective: Track the status of identified risks (SMB and Apache vulnerabilities) to ensure mitigation effectiveness and detect re-emergence or new threats.

Scope: Applies to the Linux server (192.168.1.100) and its SMB and HTTP services.

Procedure Steps:

Vulnerability Scanning:

Frequency: Weekly

Tool: Nmap or OpenVAS

Action: Run a targeted scan on 192.168.1.100 to check for SMB (port 445) and Apache (port 80) vulnerabilities. `nmap -sV -p 80,445 --script vuln 192.168.1.100 -oN weekly_scan.txt`

Output: Review scan results for open ports, service versions, or new vulnerabilities.

Justification: Regular scans detect if patches are reverted, new vulnerabilities arise, or services are re-enabled.

Log Monitoring:

Frequency: Daily

Tool: SIEM (e.g., Splunk) or log aggregation (e.g., ELK Stack)

Action: Monitor firewall and server logs for:

Connections to port 445 (SMB) from unauthorized IPs.

Suspicious HTTP requests to port 80 (e.g., path traversal attempts like ../).

Example SIEM query: `index=firewall dst_port=445 | stats count by src_ip`

`index=apache status=404 | search "GET *.*/*"`

Output: Alerts for unauthorized access attempts or exploit patterns.

Justification: Log monitoring provides real-time detection of exploitation attempts.

Patch Verification:

Frequency: Monthly

Tool: Manual verification or vulnerability management tool (e.g., Nessus)
Action: Verify Samba and Apache versions on the server.samba --version
apache2 -v

Output: Confirm versions are up-to-date (e.g., Samba 4.15+, Apache 2.4.51+).
Justification: Ensures patches remain applied and no unauthorized downgrades occur.

Incident Reporting:
Frequency: As needed
Action: Document any detected issues (e.g., new vulnerabilities, exploit attempts) in an incident report.
Template: Incident ID: [Generate UUID]
Date: [YYYY-MM-DD]
Risk: [SMB/Apache Vulnerability]
Finding: [e.g., Port 445 open, Suspicious HTTP request]
Action Taken: [e.g., Blocked IP, Re-applied patch]
Status: [Open/Closed]

Output: Centralized incident log for tracking and audit purposes.
Justification: Documentation ensures accountability and supports post-incident analysis.

Review and Update:
Frequency: Quarterly
Action: Review the monitoring procedure for effectiveness and update based on new threats or organizational changes.
Output: Updated procedure document.
Justification: Keeps the procedure relevant to evolving threat landscapes.

Evidence of Functionality:
Sample Scan Output (simulated):\$ cat weekly_scan.txt
Nmap scan report for 192.168.1.100
PORT STATE SERVICE VERSION
80/tcp open http Apache 2.4.51 (patched)
445/tcp closed smb (disabled)

Sample SIEM Alert (simulated):Alert: Suspicious HTTP Request
Timestamp: 2025-05-01 09:15:22
Source IP: 203.0.113.10
Request: GET ../../etc/passwd HTTP/1.1
Action: Blocked by WAF

Sample Incident Report (simulated):Incident ID: 7c4f3b2e-9a1d-4e5f-8c9a-3f7e2b1d6c4e
Date: 2025-05-01

Risk: Apache Vulnerability
Finding: Attempted path traversal detected
Action Taken: IP blocked, WAF rule updated
Status: Closed

3.2 Justification for Procedure

Comprehensive Coverage: The procedure combines proactive scanning, real-time monitoring, and periodic verification to ensure risks are tracked effectively.

Automation and Scalability: Tools like Nmap, SIEM, and scripts automate repetitive tasks, making the procedure scalable for larger environments.

Actionable Outputs: Alerts, reports, and logs provide clear evidence of risk status, enabling quick response to issues.

Alignment with Standards: The procedure aligns with frameworks like NIST SP 800-53 (Risk Monitoring) and ISO 27001 (Continuous Improvement).

4. Conclusion

This risk management strategy identified two critical risks from vulnerability scan results: an SMB vulnerability (EternalBlue) and an outdated Apache version (CVE-2021-41773). Treatment recommendations include patching, disabling unnecessary services, and implementing access controls, with detailed mitigation steps to reduce risk. The risk monitoring procedure ensures ongoing tracking through regular scans, log monitoring, patch verification, and incident reporting. All decisions are justified based on likelihood, impact, and industry best practices, providing a robust framework for managing cybersecurity risks.